

GLOBALTECH LIMITED

Vulnerability Management Report

Assignment Three — Drafting a Vulnerability Management Report

Prepared for: GlobalTech Limited — Senior Management

Prepared by: Marco Helie — Vulnerability Management Team

AEC Cybersecurity Prevention and Intervention

Collège Vanier — Continuing Education

Report Date: September 11, 2026

Table of Contents

Executive Summary	3
Part A — Vulnerability Review and Analysis	3
A.1 Summary of Identified Vulnerabilities	3
A.2 Detailed Vulnerability Analysis (V-21 to V-30)	3
A.3 Top 5 Highest-Risk Vulnerabilities and Justification	6
Part B — Vulnerability Management Report	6
1. Overview	6
2. Scope of the Assessment	7
3. Methodology	8
4. Vulnerability Findings	8
5. Recommendations & Mitigation	10
6. Conclusion & Next Steps	11

Executive Summary

This report presents the results of a vulnerability assessment conducted for GlobalTech across six technology domains: network infrastructure, hosts, web applications, APIs, cloud object storage, and containerized microservices. Ten vulnerabilities (V-21 through V-30) were identified: **2 Critical, 6 High, and 2 Medium**.

Part A analyzes each vulnerability — description, potential security impact, likely attack scenario, and affected CIA Triad elements — then applies a risk-based methodology (exposure, impact, and likelihood, beyond CVSS alone) to identify and justify the five highest-risk findings: **V-28, V-24, V-21, V-25, and V-26**. **Part B** presents the formal Vulnerability Management Report requested by senior management: overview, scope, methodology and risk-rating scale, findings in tabular format, prioritized remediation and mitigation recommendations, and next steps.

Part A — Vulnerability Review and Analysis

A.1 Summary of Identified Vulnerabilities

Table 1. Summary of vulnerabilities identified at GlobalTech

ID	Asset Type	Affected Asset	Vulnerability Name	Exposure	Severity	CVSS
V-21	Network	VPN Gateway	Weak Authentication Configuration	Internet-facing	High	8.4
V-22	Network	Internal DNS Server	Zone Transfer Enabled	Internal	Medium	6.5
V-23	Host	Linux Application Server	Unpatched Kernel Vulnerability	Internal	High	7.8
V-24	Host	Active Directory Domain Controller	Excessive Privileged Group Membership	Internal	Critical	9.7
V-25	Web Application	Public Web Portal	Insecure Session Management	Internet-facing	High	8.2
V-26	Web Application	Internal HR Application	Missing Access Control	Internal	High	8.0
V-27	API	Partner Integration API	Lack of Rate Limiting	Internet-facing	Medium	6.9
V-28	Cloud	Object Storage (Blob/S3)	Publicly Accessible Storage	Internet-facing	Critical	9.5
V-29	Microservice	Order Processing Service	Insecure Inter-Service Communication	Internal	High	8.1
V-30	Container	CI/CD Build Pipeline	Container Running as Root	Internal	High	7.9

A.2 Detailed Vulnerability Analysis

V-21 — Weak Authentication Configuration (VPN Gateway) *Network · Internet-facing · High · CVSS 8.4*

Description: The VPN gateway — GlobalTech's primary remote-access entry point — relies on single-factor authentication and still permits legacy protocols that lack modern protections such as MFA and strong cryptographic negotiation.

Potential security impact: One compromised password is enough to obtain authenticated access to the internal network, bypassing the perimeter and making every internal finding in this report (V-22 through V-30) directly reachable by an external attacker.

Likely attack scenario: An attacker replays credentials from a phishing campaign or a third-party leak against the internet-facing VPN portal; with no second factor to stop the login, the attacker connects as a legitimate user and begins internal reconnaissance.

CIA Triad affected: Confidentiality, Integrity, and Availability — the VPN is a gateway to all internal systems and data.

V-22 — Zone Transfer Enabled (Internal DNS Server) *Network · Internal · Medium · CVSS 6.5*

Description: The internal DNS server allows AXFR zone transfers to unauthorized hosts, so any system on the internal network can download the complete DNS zone — the full map of GlobalTech's hostnames and IP addresses.

Potential security impact: The attacker receives a reconnaissance blueprint: server names often reveal roles (e.g., *hr-db01*, *dc01*), enabling precise targeting of high-value assets without noisy network scanning.

Likely attack scenario: From any internal foothold (a phished workstation, a rogue device), the attacker issues a single zone-transfer request, silently enumerates the network topology, and plans lateral movement toward the domain controller and application servers.

CIA Triad affected: Confidentiality (disclosure of network topology); no direct Integrity or Availability impact, but it enables attacks against both.

V-23 — Unpatched Kernel Vulnerability (Linux Application Server) *Host · Internal · High · CVSS 7.8*

Description: The production Linux server runs a kernel affected by a publicly disclosed local privilege escalation vulnerability with available exploit code, allowing a low-privileged local user or process to elevate to root.

Potential security impact: Any limited access to the host — a compromised application account or web-facing service — can be converted into full root control, exposing all application data and any credentials or keys stored on the server.

Likely attack scenario: After obtaining low-privileged code execution on the host, the attacker runs a public kernel exploit to gain root, installs a persistent backdoor, and uses the server as a staging point for lateral movement.

CIA Triad affected: All three — root access exposes data (C), permits arbitrary modification (I), and allows shutdown of hosted services (A).

V-24 — Excessive Privileged Group Membership (AD Domain Controller) *Host · Internal · Critical · CVSS 9.7*

Description: Standard, non-administrative user accounts have been granted Domain Admin privileges in Active Directory, violating least privilege. These ordinary accounts carry ordinary risks — phishing, password reuse, credential theft.

Potential security impact: Compromise of any one of these accounts equals full domain compromise: the attacker can create backdoor accounts, reset any password, deploy software or ransomware to every domain-joined system, access all data, and erase logs.

Likely attack scenario: An attacker phishes a regular employee whose account was mistakenly granted Domain Admin rights, authenticates to the domain controller, dumps the credential database, and establishes persistent privileged access (e.g., a Golden Ticket) within minutes.

CIA Triad affected: All three at maximum severity — total exposure of domain credentials (C), unrestricted modification of identities and systems (I), and the ability to disrupt the entire environment (A).

V-25 — Insecure Session Management (Public Web Portal) *Web App · Internet-facing · High · CVSS 8.2*

Description: The public portal generates predictable session IDs and does not invalidate them on logout, so sessions remain valid after users believe they have logged out — and their values can be guessed.

Potential security impact: Attackers can hijack active or abandoned sessions without any password, impersonating customers or staff and performing any action the legitimate user could.

Likely attack scenario: The attacker analyzes the predictable ID pattern from their own sessions, scripts requests with reconstructed IDs of recently active users, and — because old IDs are never invalidated — retains silent account access even days later.

CIA Triad affected: Confidentiality and Integrity — account data exposure and unauthorized actions under the victim's identity.

V-26 — Missing Access Control (Internal HR Application) *Web App · Internal · High · CVSS 8.0*

Description: The HR application fails to enforce authorization checks, allowing any authenticated user to access HR records they are not entitled to — personal data, salaries, disciplinary files — simply by requesting restricted functions directly.

Potential security impact: Mass exposure of highly sensitive employee data to any internal user, creating serious privacy, legal, and regulatory exposure, and supplying prime material for targeted social-engineering attacks.

Likely attack scenario: A malicious insider — or an external attacker using one stolen employee account — notices that record URLs are not access-controlled and browses or bulk-downloads other employees' files without triggering any authorization failure.

CIA Triad affected: Primarily Confidentiality; secondary Integrity risk if the missing checks also apply to record modification.

V-27 — Lack of Rate Limiting (Partner Integration API) *API · Internet-facing · Medium · CVSS 6.9*

Description: The partner API enforces no rate limiting or throttling, allowing unlimited request volume from any client and leaving authentication endpoints open to high-speed brute-force attacks.

Potential security impact: Credential-guessing attacks proceed at machine speed until valid partner credentials are found, and a malicious or malfunctioning client can exhaust resources, degrading service for legitimate partners.

Likely attack scenario: An attacker scripts millions of credential combinations against the login endpoint from rotating IPs; with no throttling or lockout, the attack runs uninterrupted until valid credentials are recovered.

CIA Triad affected: Availability (resource exhaustion) and Confidentiality (via brute-forced partner credentials).

V-28 — Publicly Accessible Storage (Cloud Object Storage) *Cloud · Internet-facing · Critical · CVSS 9.5*

Description: A cloud storage bucket containing sensitive files is configured for public, unauthenticated access — anyone on the internet who knows or guesses the URL can list and download its contents.

Potential security impact: Immediate, unauthenticated mass exposure of sensitive data. This is a data breach in its simplest form: the exposure exists right now, requires zero attacker skill, and public buckets are continuously scanned and indexed by automated tools.

Likely attack scenario: Automated scanners that enumerate cloud storage naming conventions discover the bucket within hours of the misconfiguration; the attacker simply browses the listing and downloads everything — GlobalTech's first warning may be a public leak notification.

CIA Triad affected: Primarily Confidentiality; Integrity and Availability are also at risk if public write permissions accompany read access (tampering, deletion).

V-29 — Insecure Inter-Service Communication (Order Processing Service) *Microservice · Internal · High · CVSS 8.1*

Description: The order processing microservice communicates with peer services with no authentication and no encryption, implicitly trusting any traffic that originates from inside the network.

Potential security impact: An attacker positioned inside the network can intercept order and customer data in transit, impersonate a trusted service, and inject fraudulent orders or manipulate transactions without any credentials — undermining the zero-trust assumption of the architecture.

Likely attack scenario: After compromising one internal pod or host, the attacker passively sniffs inter-service traffic to harvest data, then issues unauthenticated requests to internal endpoints to create, modify, or redirect orders for financial gain.

CIA Triad affected: All three — interception (C), forged or manipulated orders (I), and disruption of order processing (A).

V-30 — Container Running as Root (CI/CD Build Pipeline) *Container · Internal · High · CVSS 7.9*

Description: Build containers in the CI/CD pipeline execute as the root user rather than a dedicated non-privileged account — in an environment that routinely fetches and executes code from multiple sources.

Potential security impact: Compromise of a build container — via a poisoned dependency or malicious build script — grants root inside the container, easing escape to the host and enabling theft of pipeline secrets or injection of backdoors into every artifact the pipeline builds (a supply-chain compromise).

Likely attack scenario: An attacker submits a crafted dependency that executes during the pipeline run; running as root, the malicious code harvests registry credentials, signing keys, and deployment tokens, then pivots to the host and wider cluster.

CIA Triad affected: All three — theft of secrets and code (C), tampered build outputs (I), and disruption of the release process (A).

A.3 Top 5 Highest-Risk Vulnerabilities and Justification

Ranking methodology. CVSS measures technical severity in a vacuum — it ignores where the asset sits, what it protects, and how likely real exploitation is. The ranking below therefore combines four factors: **exposure** (internet-facing assets are reachable by anyone; internal assets generally need a prior foothold), **impact** (asset sensitivity and blast radius), **likelihood** (skill required, exploit availability, attacker motivation), and the **CVSS baseline**.

Table 2. Top 5 highest-risk vulnerabilities with multi-factor justification

Rank	ID	Asset	CVSS	Rationale (Exposure / Impact / Likelihood)
1	V-28	Cloud Object Storage	9.5 (Critical)	Internet-facing, trivially exploitable, immediately damaging. Sensitive files are downloadable by anyone with no credentials and no exploit; automated scanners find public buckets within hours. Maximum likelihood plus Critical severity makes this the most urgent finding despite ranking second in raw CVSS.
2	V-24	AD Domain Controller	9.7 (Critical)	Highest CVSS and largest blast radius. Ordinary user accounts holding Domain Admin rights mean one phished password equals full domain takeover. Although internal, likelihood is high because the entry vector is everyday credential theft, not a complex exploit. Ranked just below V-28 only because it requires that initial credential compromise rather than zero effort.
3	V-21	VPN Gateway	8.4 (High)	The front door to the internal network. Internet-facing with single-factor authentication while credential phishing and stuffing are the most common breach vectors. A successful login converts every internal finding (V-22 through V-30) from "internal-only" to "attacker-reachable," multiplying the effective risk of six other findings.
4	V-25	Public Web Portal	8.2 (High)	Internet-facing, automatable, directly harming customers. Predictable session IDs plus no logout invalidation enable account takeover at scale with no password theft. Session attacks are well understood and scriptable, and the public portal carries direct privacy and reputational exposure.
5	V-26	Internal HR Application	8.0 (High)	Certain exploitation by any insider, against the most sensitive personal data GlobalTech holds. Missing access control needs no exploit — any authenticated employee (or one stolen account) can read salary, personal, and disciplinary records. Insider and stolen-credential scenarios are both realistic, and the privacy/legal exposure elevates impact beyond what internal-only placement suggests.

Why the remaining five are excluded. V-29 (8.1) and V-23 (7.8) require an attacker to already hold an internal foothold or local access — a meaningful likelihood discount. V-30 (7.9) is serious given CI/CD's supply-chain role, but requires first breaching the build environment. V-27 (6.9) and V-22 (6.5) are Medium severity: damaging as enablers, but with more limited direct impact. This exclusion is about sequence, not dismissal — all ten findings carry remediation guidance in Part B, Section 5.

Part B — Vulnerability Management Report

1. Overview

1.1 Context of the Organization

GlobalTech Limited is a mid-sized technology organization operating a hybrid environment: on-premises network and server infrastructure, public-facing web applications, partner integration APIs, cloud object storage, and a containerized microservices platform supported by an automated CI/CD pipeline. Senior management commissioned this vulnerability assessment to obtain a clear picture of the organization's security posture and an actionable risk-reduction plan. This document presents the results of that assessment, simulating an attacker operating from the internet as well as from inside the corporate network.

1.2 Objectives of the Assessment

- What is GlobalTech's current risk posture across its network, host, web application, API, cloud, and microservice environments?
- Which vulnerabilities expose the organization from the internet, and which from within?
- Which findings represent the highest remediation priority, considering exposure, impact, and likelihood — not CVSS alone?
- What concrete remediation and mitigation actions should be taken, and in what order?

1.3 Description of Client Environment

- **Network:** internet-facing VPN gateway, internal DNS servers;
- **Hosts:** Linux application servers, Active Directory domain controller;
- **Web applications:** public customer web portal, internal HR application;
- **APIs:** internet-facing partner integration API;
- **Cloud:** object storage (Blob/S3) for files and backups;
- **Microservices/containers:** order processing service, CI/CD container build pipeline.

1.4 Results of the Assessment

The assessment identified **10 vulnerabilities** across the in-scope assets, distributed as follows.

Table 3. Vulnerabilities per severity level

Total	Critical	High	Medium	Low
10	2	6	2	0

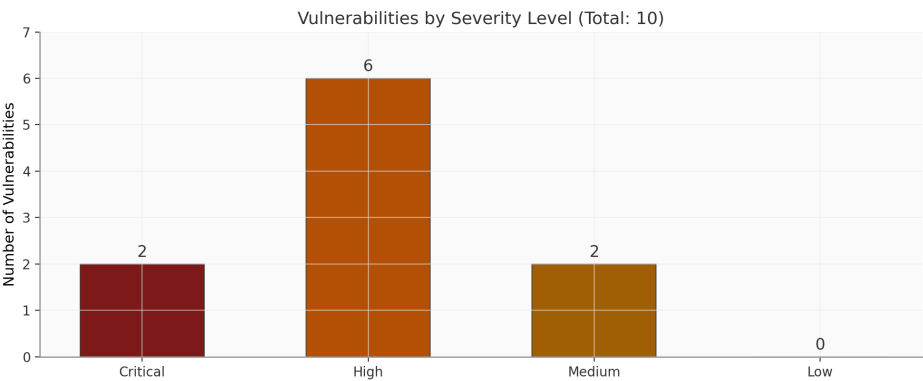


Figure 1. Distribution of identified vulnerabilities by severity level

Four findings affect internet-facing assets (V-21, V-25, V-27, V-28) and are directly reachable by external attackers; the remaining six are internal findings whose exploitation generally requires an initial foothold — one that V-21 (weak VPN authentication) could readily provide.

2. Scope of the Assessment

2.1 Scope

- **External vulnerability assessment:** VPN gateway, public web portal, partner integration API, and cloud object storage configuration;
- **Internal vulnerability assessment:** DNS infrastructure, Linux application servers, Active Directory domain services, internal HR application, inter-service communication, and the CI/CD build environment;
- **Configuration and access-control review:** authentication mechanisms, authorization enforcement, privileged group membership, and cloud storage permissions.

Out of scope: social-engineering exercises, physical security, and denial-of-service testing against production systems.

2.2 Assessment Schedule

- **Start date:** September 1, 2026 • **End date:** September 8, 2026 • **Report date:** September 11, 2026

3. Methodology

3.1 Risk Rating Definitions

Findings are rated using CVSS v3.x base scores mapped to the qualitative bands below. Final prioritization (Part A, Section A.3) additionally weighs exposure, asset criticality, and exploitation likelihood.

Table 4. Risk rating scale used for this assessment

Level	CVSS Score	Description
Critical	9.0 – 10.0	Easily exploited; leads to complete system compromise or direct, large-scale exposure of sensitive data. Immediate remediation required.
High	7.0 – 8.9	Exploitation can cause significant loss of confidentiality, integrity, or availability (privilege escalation, account takeover, unauthorized access to sensitive records). Schedule at high priority in the current cycle.
Medium	4.0 – 6.9	Weakens security posture or enables further attacks (information disclosure, missing hardening) without directly providing compromise. Remediate within the standard cycle.
Low	0.1 – 3.9	Minor issues and best-practice deviations with limited direct impact; addressed through routine hardening.

3.2 Tools and Techniques Used

Tools and techniques are conceptual, per the assignment guidelines.

- **Nmap** — network discovery, port scanning, service enumeration;
- **Nessus / Qualys** — authenticated and unauthenticated vulnerability scanning of network devices and hosts;
- **Burp Suite / OWASP ZAP** — web application and API testing (session management, access control, rate limiting);
- **BloodHound / PingCastle** — Active Directory privileged group and configuration review;
- **Prowler / ScoutSuite** — cloud storage permissions and posture review;
- **Trivy / kube-bench** — container image, runtime privilege, and pipeline configuration review;
- **Metasploit** — conceptual validation of exploitability for selected high-severity findings.

3.3 Assessment Method

The assessment followed a five-phase vulnerability management lifecycle: **(1) Discovery** — enumeration of in-scope hosts, services, applications, and cloud resources; **(2) Identification** — automated and manual testing with verification to eliminate false positives; **(3) Analysis** — each confirmed finding documented with description, impact, attack scenario, and CIA Triad elements (Part A); **(4) Prioritization** — risk-based ranking combining CVSS with exposure, asset criticality, and likelihood; **(5) Reporting** — this document.

4. Vulnerability Findings

The following vulnerabilities were identified during the assessment, ordered by severity (Critical, High, Medium).

4.1 V-24 — Excessive Privileged Group Membership

Severity	Critical (CVSS 9.7) Asset: Active Directory Domain Controller (Host) Exposure: Internal
Description	Non-administrative user accounts hold membership in privileged groups, including Domain Admin. Compromise of any one of these ordinary accounts — through phishing or credential theft — is equivalent to full domain compromise: unrestricted control over all identities, systems, and data in the Active Directory environment.
Recommendation	Immediately audit and remove unnecessary privileged group memberships; enforce least privilege with separate MFA-protected admin accounts; implement just-in-time elevation and continuous monitoring of privileged group changes.

4.2 V-28 — Publicly Accessible Storage

Severity	Critical (CVSS 9.5) Asset: Cloud Object Storage (Blob/S3) Exposure: Internet-facing
Description	A storage bucket containing sensitive files allows public, unauthenticated access — contents are listable and downloadable by anyone on the internet. No exploit is required, and public buckets are continuously enumerated by automated scanners: this is an active, ongoing data exposure.
Recommendation	Immediately revoke public access and enforce private-by-default bucket policies; audit access logs for signs of prior exfiltration; deploy automated cloud posture monitoring with alerts on any public- exposure misconfiguration.

4.3 V-21 — Weak Authentication Configuration

Severity	High (CVSS 8.4) Asset: VPN Gateway (Network) Exposure: Internet-facing
Description	The VPN gateway accepts single-factor authentication and legacy protocols. A single phished, reused, or brute-forced password grants authenticated access to the internal network, bypassing the perimeter and exposing every internal asset to the attacker.
Recommendation	Enforce MFA for all VPN access; disable legacy authentication protocols; add failed-login lockout and anomaly alerting; review VPN logs for signs of prior unauthorized access.

4.4 V-25 — Insecure Session Management

Severity	High (CVSS 8.2) Asset: Public Web Portal (Web Application) Exposure: Internet-facing
Description	Session IDs are predictable and are not invalidated on logout, allowing attackers to reconstruct or reuse valid sessions and hijack user accounts without any password — scriptable at scale against the public portal.
Recommendation	Generate session IDs with a cryptographically secure random generator; invalidate sessions server-side at logout and after inactivity; set Secure, HttpOnly, and SameSite cookie attributes; alert on concurrent or anomalous session use.

4.5 V-29 — Insecure Inter-Service Communication

Severity	High (CVSS 8.1) Asset: Order Processing Service (Microservice) Exposure: Internal
Description	Microservices communicate with no authentication and no encryption. An attacker inside the network can intercept order and customer data in transit, impersonate trusted services, and issue unauthorized requests — including fraudulent orders — without any credentials.
Recommendation	Implement mutual TLS (mTLS) for all service-to-service communication (a service mesh can deliver this uniformly); enforce service identity and authorization policies; segment the network so only explicitly permitted services can communicate.

4.6 V-26 — Missing Access Control

Severity	High (CVSS 8.0) Asset: Internal HR Application (Web Application) Exposure: Internal
-----------------	--

Description	The HR application does not enforce authorization checks on record access: any authenticated user can read HR records — personal data, salaries, disciplinary files — belonging to other employees. Exploitation requires no technical skill, creating serious privacy and regulatory exposure.
Recommendation	Enforce server-side role-based access control on every record and function; restrict HR data to authorized HR roles; add access logging with alerts on bulk or unusual record access; include authorization tests in the regression suite.

4.7 V-30 — Container Running as Root

Severity	High (CVSS 7.9) Asset: CI/CD Build Pipeline (Container) Exposure: Internal
Description	Build containers execute as root. Compromise of a build container — through a malicious dependency or poisoned build script — grants root inside the container, easing escape to the host and enabling theft of pipeline secrets or backdoor injection into build artifacts (supply-chain compromise).
Recommendation	Rebuild images to run as a dedicated non-root user; enforce non-root execution via admission policies (e.g., Pod Security Standards); isolate the build environment and scope pipeline secrets to short-lived, minimal permissions; scan dependencies before execution.

4.8 V-23 — Unpatched Kernel Vulnerability

Severity	High (CVSS 7.8) Asset: Linux Application Server (Host) Exposure: Internal
Description	The server runs a kernel affected by a publicly disclosed local privilege escalation flaw with available exploit code. Any low-privileged local access can be elevated to root — full control of the host, its application data, and stored credentials.
Recommendation	Apply the vendor kernel patch at the next emergency maintenance window; establish a recurring patching cadence; restrict local access to the minimum necessary accounts; monitor for privilege-escalation indicators.

4.9 V-27 — Lack of Rate Limiting

Severity	Medium (CVSS 6.9) Asset: Partner Integration API (API) Exposure: Internet-facing
Description	The partner API enforces no request rate limiting, leaving authentication endpoints open to high-speed brute-force and credential-stuffing attacks, and the service itself open to resource exhaustion that degrades availability for legitimate partners.
Recommendation	Implement per-client rate limiting and throttling at the API gateway; add progressive delays and temporary lockouts on repeated authentication failures; deploy anomaly detection on request volumes.

4.10 V-22 — Zone Transfer Enabled

Severity	Medium (CVSS 6.5) Asset: Internal DNS Server (Network) Exposure: Internal
Description	The DNS server permits zone transfers to unauthorized hosts, exposing the complete DNS zone — a full map of hostnames, roles, and IP addresses. Not directly exploitable for compromise, but it gives an attacker with any internal foothold silent, precise reconnaissance that accelerates subsequent attacks.
Recommendation	Restrict zone transfers to authorized secondary DNS servers by IP, protected with TSIG keys; monitor DNS logs for unauthorized AXFR attempts as an early-warning reconnaissance indicator.

5. Recommendations & Mitigation

Recommendations are organized by priority tier, aligned with the Top 5 ranking from Part A. Each finding pairs an **immediate remediation** with a **short-term mitigation** — an interim compensating control that reduces risk while the permanent fix is implemented and tested.

5.1 Priority 1 — Critical Findings (Immediate Action, 0–7 Days)

V-28 — Publicly Accessible Storage. *Immediate:* revoke all public access on the bucket and enforce private-by-default storage policies across the cloud tenant; audit access logs and invoke incident response and breach-notification procedures

if exfiltration is confirmed. *Mitigation:* enable automated cloud posture management with alerting on any public-access change, so recurrence is detected within minutes.

V-24 — Excessive Privileged Group Membership. *Immediate:* remove non-administrative accounts from Domain Admin and other privileged groups; require separate, MFA-protected admin accounts; audit recent privileged activity. *Mitigation:* deploy continuous monitoring with automatic alerts on privileged group changes and adopt just-in-time elevation to minimize standing privileges.

5.2 Priority 2 — Internet-Facing High Findings (Expedited, 1–4 Weeks)

V-21 — Weak VPN Authentication. *Immediate:* deploy MFA for all VPN connections and disable legacy protocols. *Mitigation:* enforce strong-password and lockout policies and alert on unusual login patterns (impossible travel, off-hours access) until MFA is fully rolled out.

V-25 — Insecure Session Management. *Immediate:* replace session ID generation with a cryptographically secure mechanism and enforce server-side invalidation at logout and after idle timeout. *Mitigation:* shorten session lifetimes and apply Secure/HttpOnly/SameSite cookie flags immediately as configuration changes.

5.3 Priority 3 — Internal High Findings (Current Cycle, 30–60 Days)

V-26 — Missing Access Control (HR). Enforce server-side role-based authorization on every record and function, with access logging and bulk-read alerts. *Mitigation:* restrict network reachability of the HR application to authorized user groups until the fix is verified.

V-29 — Insecure Inter-Service Communication. Roll out mTLS and service identity for all microservice communication, with network policies permitting only required flows. *Mitigation:* tighten segmentation around the order processing service and monitor for plaintext service calls.

V-30 — Container Running as Root. Rebuild pipeline images as non-root and enforce this via admission policy; isolate CI/CD runners and scope pipeline secrets. *Mitigation:* add dependency and build-input scanning to catch malicious code before it executes.

V-23 — Unpatched Kernel. Patch the kernel at the next emergency maintenance window and establish a recurring patching cadence. *Mitigation:* restrict local logon rights and monitor for privilege-escalation indicators until patched.

5.4 Priority 4 — Medium Findings (Standard Cycle, 60–90 Days)

V-27 — Lack of Rate Limiting: configure gateway-level rate limits, throttling, and lockouts on the partner API. **V-22 — Zone Transfer Enabled:** restrict zone transfers to authorized secondaries using TSIG and alert on unauthorized AXFR attempts.

5.5 Program-Level Recommendations

- **Patch and configuration cadence:** recurring patch windows plus automated cloud and container compliance checks;
- **Identity hardening:** MFA on all remote access, least-privilege enforcement, quarterly privileged-access reviews;
- **Secure SDLC:** SAST/DAST, secret scanning, and authorization test cases in CI/CD so findings like V-25/V-26 are caught pre-production;
- **Continuous vulnerability management:** re-scans after each remediation to verify closure, plus periodic penetration testing;
- **Monitoring and response:** centralized logging with detections for the attack scenarios in Part A (session hijacking, zone transfers, privilege escalation, brute force).

6. Conclusion & Next Steps

GlobalTech's risk posture is dominated by two Critical exposures at opposite ends of the environment — a publicly accessible cloud bucket leaking sensitive data today (V-28), and an Active Directory privilege model where one phished account could cascade into total domain compromise (V-24). Around them sit High findings on the internet-facing edge (weak VPN authentication, insecure portal sessions) and inside the network (missing HR access control, unencrypted microservice traffic, root-privileged build containers, an unpatched kernel), plus two Medium issues that act as force multipliers. The pattern is instructive: the most dangerous weaknesses are not exotic zero-days but fundamental hygiene

gaps — missing second factors, missing authorization checks, excessive privileges, and insecure defaults — all fixable with established controls.

Next steps: **(1) Week 1** — close the two Critical findings (V-28, V-24) and audit logs for prior exploitation; **(2) Weeks 1–4** — remediate the internet-facing High findings (V-21, V-25), prioritizing VPN MFA; **(3) Days 30–60** — complete the internal High findings (V-26, V-29, V-30, V-23); **(4) Days 60–90** — address the Medium findings (V-27, V-22) and implement the program-level improvements in Section 5.5; **(5) Ongoing** — re-scan after each remediation to verify closure, report progress to senior management monthly, and schedule the next full assessment. Executed in this order, GlobalTech first eliminates the exposures causing active harm, then closes the pathways an attacker would use to enter and move inside the network, and finally institutionalizes the practices that prevent recurrence — moving from reactive patching to a mature, continuous vulnerability management program.